Incident Report: Authentication Log Investigation

Cyber Security Task 4 | Synthetic log, documentation-range IPs, fictional accounts | Log date 2026-08-01 (UTC)

1. Executive summary

The log holds 12 events across 6 accounts and 4 IP addresses. Of 9 password logins, 7 failed and 2 succeeded. One clear attack pattern was found: a **password-spraying run** from 203.0.113.42 against four accounts in 12 seconds (High). The spray itself did not succeed. One account it touched, stu-311, later had a successful login from a new IP and device; the log cannot show whether that is the real student or an attacker, so it is flagged **needs verification** (Medium severity, Low confidence). A cluster of three failures on stu-117 is most likely an ordinary user mistake, and the lockout worked. The rate limit only covered stu-209, which is a control gap.

2. Scope and method

Data: the supplied synthetic authentication log (12 rows). All IPs were confirmed to be RFC 5737 documentation ranges, so nothing here refers to real systems. Work was done offline on the CSV only; no external systems were scanned.

Step 1 - Normalization. Timestamps parsed and converted to UTC; IPs validated and tagged by documentation range; account IDs, events, results and devices trimmed and lower-cased; events split into *authentication* vs *system_control*. Important detail: 'account_lock / success' means the system locked an account, so it is not counted as a login success.

Step 2 - Baseline. stu-104 logs in from 192.0.2.18 (android) and refreshes a token 75 minutes later from the same IP and device. That is the normal pattern used for comparison.

3. Detection rules

ID	Rule	Logic	Possible false positive	Hits
R1	Brute force	3+ failed password_login for the SAME account from the SAME IP within 120 s.	Users who forgot their password (see F3).	1
R2	Password spraying	3+ DIFFERENT accounts failing from the SAME IP within 60 s.	Shared campus/NAT IPs at class start.	1
R3	Unusual access after targeting	Successful login for an account that was targeted by a flagged spray IP in the last 24 h, from a different IP and a device not previously seen for that account.	Student legitimately logging in on a new phone.	1

4. Findings

ID	Subject	Assessment	Sev / Conf	Reasoning
F1	203.0.113.42 -> stu-209, stu-311, stu-415, stu-502 09:21:10 - 09:21:22 (12 s)	Suspicious	High / High	One IP tried four different accounts in 12 seconds, one attempt each, from an 'unknown' device. One try per account stays under per-account lockout limits, which is the typical spraying pattern.
F2	stu-311 from 192.0.2.99 (ios) Targeted 09:21:13; success 11:47:09 (146 min later)	Needs verification	Medium / Low	stu-311 was sprayed, then logged in successfully from an IP and device not seen for this account elsewhere in the log. But the spray attempt FAILED and came from a different IP, so the log alone does not link the two.
F3	198.51.100.27 -> stu-117 09:03:44 - 09:04:18 (34 s), lock at 09:05:03	Likely user mistake	Low / Medium	Three failures about 17 s apart, one account, one IP, one consistent device ('windows'), no other accounts touched, and no attempts after the lock. This looks like a person retyping a forgotten password, though the log has no failure reason to prove it. The lock control worked.
F4	rate_limit event covers stu-209 only 09:22:01	Control weakness	Medium / Medium	Only one rate_limit/blocked event exists, for stu-209, 39 s after the last spray attempt. Nothing in the log shows the IP itself being blocked or the other three accounts being protected.
F5	stu-104 from 192.0.2.18 (android) 09:00:12 and 10:15:32	Benign	Info / High	Password login then a refresh token about 75 min later, same IP and device. Consistent, healthy pattern.

5. Timeline (2026-08-01, UTC) - evidence kept separate from assumptions

Time	Evidence (what the log shows)	Assumption / interpretation	Row
09:00:12	stu-104 password_login success, 192.0.2.18, android	Normal start-of-day login (baseline).	2
09:03:44	stu-117 password_login failure, 198.51.100.27, windows	Possibly a mistyped password.	3
09:04:01	stu-117 password_login failure (same IP/device)	Same as above.	4
09:04:18	stu-117 password_login failure (3rd in 34 s)	Crosses the R1 threshold.	5
09:05:03	account_lock on stu-117 by server (lock applied)	Control worked; no further stu-117 events logged.	6
09:21:10	stu-209 failure from 203.0.113.42, device unknown	Start of spray run.	7
09:21:13	stu-311 failure from 203.0.113.42	Second account in 3 s.	8
09:21:17	stu-415 failure from 203.0.113.42	Third account.	9
09:21:22	stu-502 failure from 203.0.113.42	Fourth account; run likely automated.	10
09:22:01	rate_limit blocked on stu-209 by server	Scope of the block is unknown (account or IP).	11
10:15:32	stu-104 refresh_token success, 192.0.2.18, android	Normal session continuation.	12
11:47:09	stu-311 password_login success, 192.0.2.99, ios	Could be the real student on a new phone OR an attacker with a credential from elsewhere.	13

6. Evidence vs assumptions

Claim	Evidence	Assumption (not proven)	How to verify
One IP attacked four accounts	Rows 7-10: 203.0.113.42, 4 users, 12 s.	That it was a single actor / script.	Check web-server request logs for user agent and request IDs.
Spray did not succeed	All four attempts are 'failure'; no success from 203.0.113.42.	That there were no attempts outside this log.	Review the full log window before and after 09:21.
stu-117 is probably a user mistake	3 failures at human pace, same device, then lock.	That a person typed them.	Ask the student; check failure reason (bad password) and prior logins.
stu-311 login may be compromised	Success from 192.0.2.99/ios 146 min after being targeted.	That the login is linked to the spray, or that it is not the real user.	Contact the student out of band; check MFA result, session activity and device history.
Rate limit was partial	Only one rate_limit event, for stu-209.	That the other accounts were not limited by some other control.	Check rate-limit configuration and whether it is per-IP or per-account.
All activity is fictional / safe	All IPs fall in RFC 5737 documentation ranges.	None - this is a synthetic lab dataset.	n/a

7. Recommended containment

- Verify stu-311 with the student out of band. If not confirmed, force a password reset and revoke active sessions and refresh tokens.
- Block or challenge 203.0.113.42 at the edge (lab note: documentation range, fictional) and add it to a watchlist.
- Watch stu-209, stu-415 and stu-502 for successful logins from new IPs or devices for the next 24-72 hours.
- Follow up with stu-117 so the locked account is recovered by identity-checked reset, not by bypassing the lock.
- Require MFA for all student accounts, or at least when a login comes from a new IP/device.

8. Recommended logging and detection improvements

- Add a failure_reason field (bad password, unknown user, locked) so user mistakes can be told apart from attacks.
- Log user agent, auth method, MFA result, session ID and a request ID on every event.
- Record the scope and duration of rate_limit and account_lock actions (per-IP or per-account, minutes).
- Add geo/ASN enrichment and a 'first seen' flag per account for new IP/device combinations.
- Alert on: 3+ accounts failing from one IP in 60 s; 3+ failures for one account in 2 min; success from a new IP shortly after the account was targeted.
- Ship logs to central storage with synchronized clocks and protect them from tampering.

9. Limitations

The sample is tiny (12 events, about 3 hours), so there is no long-term baseline per account and thresholds are illustrative. The log has no failure reason, user agent, MFA result or rate-limit scope, so several conclusions stay assumptions. Severity and confidence are analyst judgments and should be revisited if more data becomes available.